GDPR Audit Pack — Part 4

Phase 4 & 5: Peer Review Rubric + Debrief & Divergence Analysis **Audit Partner Swap Exercise**

Reviewer: Mona | **Memo Author:** Pedro Biain | **Date Reviewed:** March 26, 2026

📋 Peer Review Rubric (Reviewer as Client)

Criterion	Score (1–3)	Reviewer Comment
Clear bottom-line recommendation	3 / 3	"GO WITH CONDITIONS" is prominently displayed at the top with a clear one-sentence reason. Excellent visibility for executive readers.
Lawful basis selection is justified	3 / 3	Legitimate interests used consistently. The DPIA reference and residual risks implicitly support the balancing test. Strong alignment.
Top actions are specific and sequenced	3 / 3	Three actions: (1) Legal Foundation (DPA/SCCs/TIA), (2) DPIA, (3) Redaction + Privacy Notice. Correct sequence—legal before technical.
Residual risks are named honestly	3 / 3	Model memorization, regulatory shift, right to be forgotten complexity—all candidly disclosed. No sugar-coating.
Law stacking is addressed (AI Act / ePrivacy)	3 / 3	AI Act: Limited Risk (Art. 50) correctly classified. ePrivacy: correctly states no new consent needed if original collection compliant. Data Act N/A.

🗣️ Client Feedback (Peer Acting as Client)

"I accept the recommendation. The sequencing of legal safeguards before technical implementation is exactly what we need. One concern: the memo references 'selective retraining' for right to be forgotten but doesn't specify how we will operationalize this. I'd ask for a redesign of the residual risks section to include a concrete commitment—either maintaining a training data registry with monthly opt-out retraining cycles or partnering with OpenAI on deletion workflows. Also, the Transfer Impact Assessment (TIA) is mentioned but not elaborated—we need assurance that US surveillance risks are formally assessed. Otherwise, the audit is thorough and actionable."

✅ Recommendation accepted with clarifications noted. The consultant will add TIA detail and model deletion workflow.

🔄 Debrief: Divergence Analysis (Partner Comparison)

Agreements: Both Mona and Pedro agreed that **legitimate interests** is the appropriate lawful basis, that a **DPIA is mandatory** due to special category data risks, and that US transfer (OpenAI) requires SCCs + DPA. Both classified the AI system as **Limited Risk** under the AI Act.

Divergence Point 1 — Profiling Transparency (Article 13/14):
Pedro's memo: Mentions updating Privacy Notice to disclose "Profiling" in the third action, but does not elaborate on the legal basis for profiling or the specific Article 13(2)(f) requirement.
Mona's memo: Explicitly calls out profiling under Article 13/14 and requires a clear objection mechanism under Article 21.
Resolution: The stronger reading is to explicitly tie profiling disclosure to Articles 13(2)(f) and 21. Mona's approach is more legally defensible. We will incorporate explicit profiling language into the final privacy notice template.

Divergence Point 2 — Transfer Impact Assessment (TIA) Depth:
Pedro's memo: Mentions TIA as part of legal foundation but does not specify that it must assess US surveillance laws (FISA 702, EO 12333) and supplementary measures.
Mona's memo: Explicitly requires TIA documenting "US surveillance law risks" and supplementary technical measures.
Resolution: Mona's requirement is stronger and aligns with EDPB Schrems II guidance. We will adopt Mona's formulation: TIA must assess third-country laws and document supplementary measures before transfer.

Divergence Point 3 — Special Category Data (Article 9) Handling:
Pedro's memo: References "inferable" Article 9 data and mandates redaction, but does

not address the legal gateway if redaction fails.

Mona's memo: Notes that redaction is technical mitigation but does not fully resolve Article 9 justification. Implies that if redaction misses sensitive data, a separate legal basis (explicit consent) may be required.

Resolution: Combined approach is strongest: redaction as primary control, plus a fallback workflow to exclude or obtain explicit consent for high-risk ticket categories (e.g., health-related support). We will add this to the DPIA scope.

> 📌 **Final Agreed Position (Post-Debrief):**
> • Maintain "GO WITH CONDITIONS" bottom line.
> • Strengthen profiling transparency with explicit Article 13(2)(f) reference.
> • Enhance TIA to include US surveillance law analysis and supplementary measures.
> • Add Article 9 fallback workflow for missed sensitive data.
> • Commit to documented training data registry to operationalize right to erasure.

✓ Peer review completed using EDPB guidelines and AI Act reference.